

Malware Analysis Lab Assessment-4

NAME: Nori Karthikey

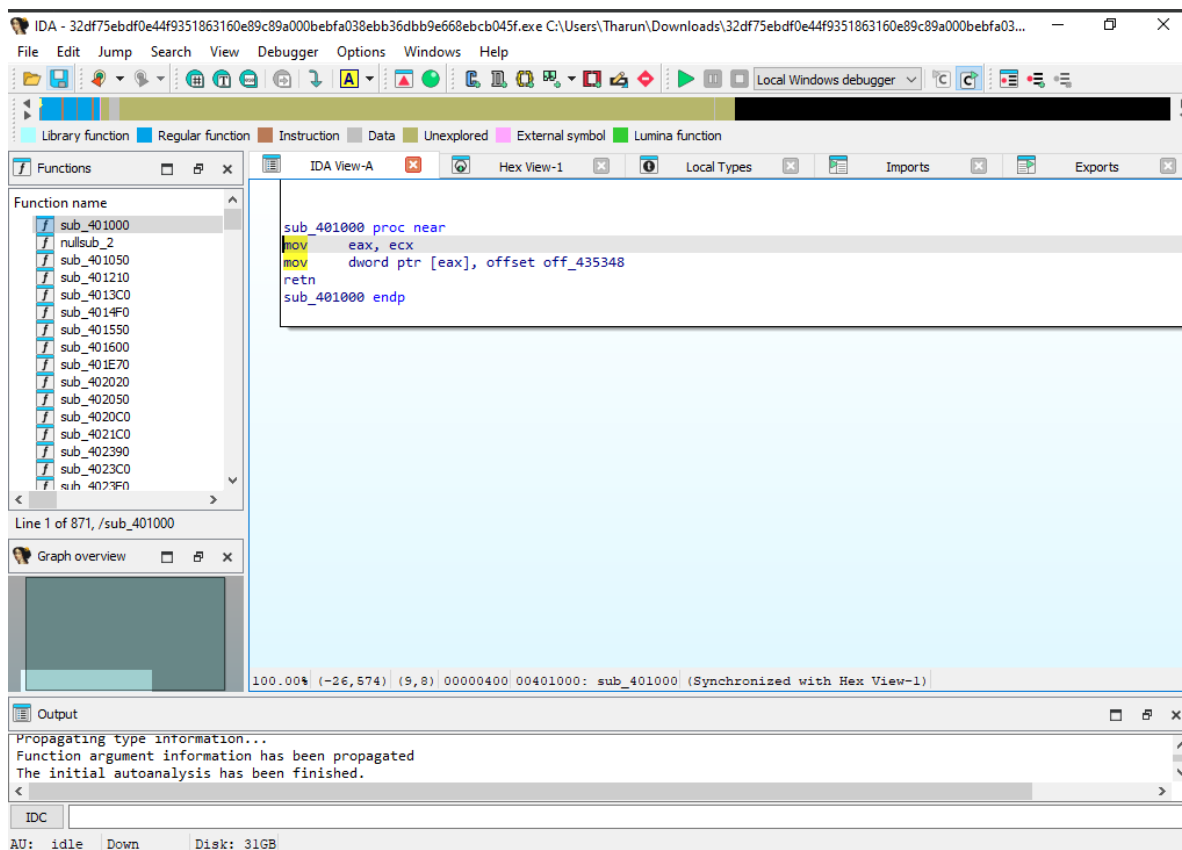
REGISTRATION NUMBER: 22BCI0052

Assignment 4:

Analyse the following malware sample using IDA Free and answer the given questions.

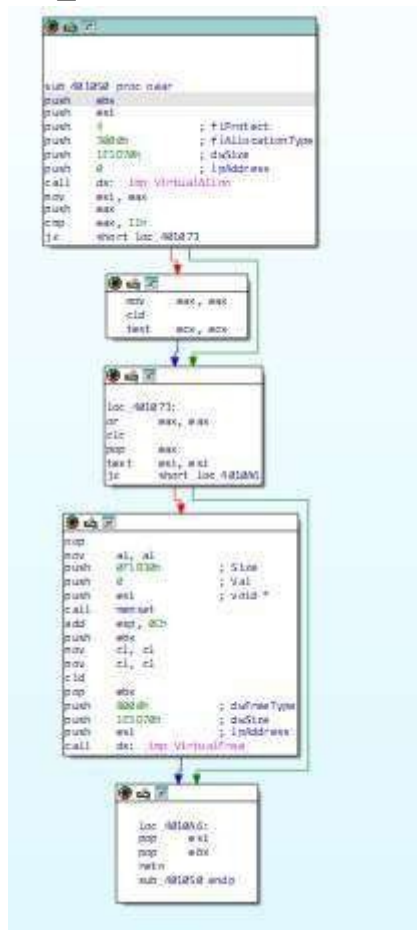
Answer the questions provided in red:

- 1) Loading and Entry Point Navigation
- 2) Load the sample into IDA Free 9.1.
- 3) IDA will auto-analyse and place you at the program's entry point (labelled start or sub_401000).
- 4) Use G (Jump to address) or the Functions window to confirm the entry point.



Was unable to find sub_412000 later realized that it was just an example.

sub_401050



imported API called is VirtualAlloc at address 0x0040105A.

The first conditional jump occurs immediately afterward. The instruction sequence test eax, eax followed by jz checks whether VirtualAlloc returned a valid pointer. If eax is zero, the jump is taken to a failure-handling block.

Q2) Searching for Suspicious Clues. Open Strings view (Shift+F12) and search for suspicious substrings (http, wininet.dll, domains).

Strings, Imports and Calls

dll

Address	Length	Type	String
.rdata:0043...	0000000D	C	kernel32.dll
.rdata:0043...	0000000C	C	dbghelp.dll
.rdata:0044...	0000000B	C	msvcrt.dll
.rdata:0044...	0000000D	C	KERNEL32.dll
.rdata:0044...	0000000B	C	USER32.dll
.rdata:0044...	0000000D	C	ADVAPI32.dll
.rdata:0044...	0000000A	C	ole32.dll
.rdata:0044...	0000000D	C	OLEAUT32.dll
.rdata:0044...	0000000C	C	SHLWAPI.dll

Urls present including 3 https

Address	Length	Type	String
.rdata:0043...	00000015	C	https://t.me/bg3goty
.rdata:0043...	00000036	C	https://steamcommunity.com/profiles/76561199601319247
.rdata:0043...	0000000F	C	HttpQueryInfoA

Domains

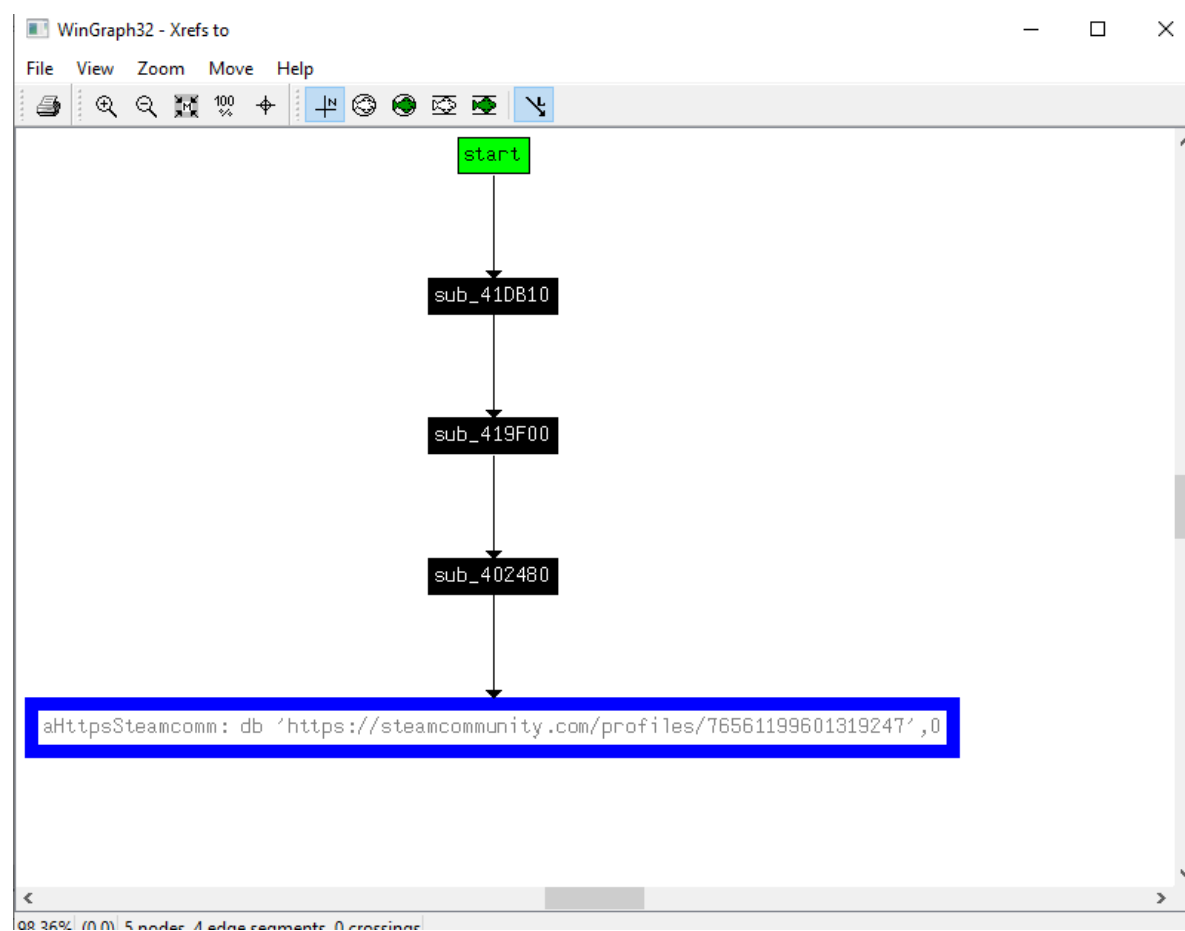
Address	Length	Type	String
.rdata:0043...	00000008	C	Login:

Address	Length	Type	String
.rdata:0043...	0000000E	C	passwords.txt
.rdata:0043...	0000000B	C	Password:
.rdata:0043...	00000009	C	Password
.rdata:0043...	00000012	C	UseMasterPassword

Searching inside one of the url the one with steam community

Address	Ordinal	Name	Library
▼ ADVAPI32			
00435000		RegOpenKeyExA	ADVAPI32
00435004		RegGetValueA	ADVAPI32
00435008		GetCurrentHwProfileA	ADVAPI32
▼ SHLWAPI			
00435170	155	__imp_StrCmpCA	SHLWAPI

Xref for steam link



```

00435380 6C 00 00 00 70 00 73 00 74 00 6F 00 72 00 65 00 C:\n.e.c.k...u.i.
004353C0 63 00 2E 00 64 00 6C 00 6C 00 00 00 64 00 69 00 l...p.s.t.o.r.e.
004353D0 72 00 5F 00 77 00 61 00 74 00 63 00 68 00 2E 00 c...d.l.l...d.i.
004353E0 64 00 6C 00 6C 00 00 00 61 00 70 00 69 00 5F 00 r...w.a.t.c.h...
004353F0 6C 00 6F 00 67 00 2E 00 64 00 6C 00 6C 00 00 00 d.l.l...a.p.i._.
00435400 73 00 62 00 69 00 65 00 64 00 6C 00 6C 00 2E 00 l.o.g...d.l.l...
00435410 64 00 6C 00 6C 00 00 00 73 00 6E 00 78 00 68 00 s.b.i.e.d.l.l...
00435420 68 00 2E 00 64 00 6C 00 6C 00 00 00 61 00 76 00 d.l.l...s.n.x.h.
00435430 67 00 68 00 6F 00 6F 00 6B 00 61 00 2E 00 64 00 k...d.l.l...a.v.
00435440 6C 00 6C 00 00 00 00 00 61 00 76 00 67 00 68 00 g.h.o.o.k.a...d.
00435450 6F 00 6F 00 6B 00 78 00 2E 00 64 00 6C 00 6C 00 l.l...a.v.g.h.
00435460 00 00 00 00 2E 2E 00 00 2E 00 00 00 5C 2A 2E 2A o.o.k.x...d.l.l.
00435470 00 00 00 00 5C 00 00 00 37 2E 33 00 62 32 35 38 .....\".*
00435480 63 66 31 36 66 31 34 66 61 61 33 37 31 35 62 64 ....\"...7.3.b258
00435490 39 34 32 63 65 63 65 38 30 33 35 65 00 00 00 00 cf16f14faa3715bd
004354A0 68 74 74 70 73 3A 2F 2F 74 2E 6D 65 2F 62 67 33 942cece8035e....
004354B0 67 6F 74 79 00 00 00 00 6D 65 64 76 73 00 00 00 https://t.me/bg3
004354C0 4D 6F 7A 69 6C 6C 61 2F 35 2E 30 20 28 58 31 31 goty....medvs...
004354D0 3B 20 55 62 75 6E 74 75 3B 20 4C 69 6E 75 78 20 Mozilla/5.0(X11
004354E0 78 38 36 5F 36 34 3B 20 72 76 3A 31 30 39 2E 30 ;Ubuntu;Linux
004354F0 29 20 47 65 63 6B 6F 2F 32 30 31 30 30 31 30 31 )Gecko/20100101
00435500 20 46 69 72 65 66 6F 78 2F 31 31 32 2E 30 20 20 Firefox/112.0
00435510 75 61 63 71 00 00 00 00 68 74 74 70 73 3A 2F 2F uacq....https://
00435520 73 74 65 61 6D 63 6F 6D 6D 75 6E 69 74 79 2E 63 steamcommunity.c
00435530 6F 6D 2F 70 72 6F 66 69 6C 65 73 2F 37 36 35 36 om/profiles/7656
00435540 31 31 39 39 36 30 31 33 31 39 32 34 37 00 00 00 1199601319247...
00435550 68 65 6C 6C 6F 00 00 00 57 46 51 59 31 32 4F 35 hello...WFQY1205
00435560 4A 36 4E 00 72 2E 24 76 14 5A 3A 1A 6F 5E 3B 00 J6N.r.$v.Z:.o^;.
00435570 33 44 41 4E 45 50 56 00 77 0D 12 1E 09 11 0F 00 3DANEPV.w.....
00435580 52 57 49 48 34 44 56 00 18 38 21 26 70 2B 33 00 RWIH4DV..8!&p+3.
00435590 32 42 35 53 54 4F 00 00 7A 03 79 6A 00 07 00 00 2B5STO..z.yj....
004355A0 42 43 45 50 4D 37 52 46 39 33 34 46 00 00 00 00 BCEPM7RF934F....
004355B0 14 0E 32 31 3F 52 04 0B 4E 52 46 23 00 00 00 00 ..21?R..NRF#....
004355C0 52 50 4F 31 4F 54 00 00 21 23 2C 50 21 32 00 00 RPO1OT...!#,P!2..

```

Byte pattern search

```

00443370 65 4F 62 6A 65 63 74 00 B5 00 43 72 65 61 74 65 eObject...Create
00443380 54 68 72 65 61 64 00 00 D2 01 47 65 74 44 72 69 Thread....GetDri
00443390 76 65 54 79 70 65 41 00 07 02 47 65 74 4C 6F 67 veTypeA...GetLog
004433A0 60 63 61 6C 44 73 60 76 65 53 74 73 60 65 67 73 fca1DriveStinger

```

Output

```

Search failed.
Command "AskBinaryText" failed
Searching down CASE-SENSITIVELY for binary pattern:
70 75 73 68 20 69 6D 6D 33 32
Searching down CASE-INSENSITIVELY for binary pattern:
68 ?? ?? ??
Search completed. Found at 0000000000443381.

```

3) Renaming for Clarity

Start to trojan_entry

Function name	Segment	Start	Length	Locals	Arguments	R	^
trojan_entry	.text	00401000	00000009	00000000		R	
sub_401050	.text	00401050	00000059	00000008		R	
sub_401210	.text	00401210	00000010	00000004	0000000C	R	
sub_4013C0	.text	004013C0	0000005D	00000014	00000004	R	
sub_4014F0	.text	004014F0	00000074	00000018		R	
sub_401550	.text	00401550	000000BF	0000001C	00000004	R	
sub_401590	.text	00401590	000000E3	00000024	00000020	R	

```

trojan_entry proc near
mov     eax, ecx
mov     dword ptr [eax], offset off_435348
retn
trojan_entry endp

```

Sub_401550 is the c2 communicate

[illegible]

Install_hook on CreateThread address

```
loc_41B273:
inc     dword_655D08
push    ebx                ; lpThreadId
push    ebx                ; dwCreationFlags
lea     edx, [ebp+Parameter]
push    edx                ; lpParameter
push    offset StartAddress ; lpStartAddress
push    ebx                ; dwStackSize
push    ebx                ; lpThreadAttributes

install_hook:
call    ds:CreateThread_0
push    3E8h                ; dwMilliseconds
push    eax                ; hHandle
call    ds:__imp_WaitForSingleObject
mov     esi, [ebp+arg_0]
push    offset unk_435476
mov     ecx, esi
call    sub_4157D0
mov     [ebp+var_10], 1
lea     ecx, [ebp+var_2C]
; } // starts at 41B1FD
; try {
mov     byte ptr [ebp+var_4], 9
call    sub_415850
```

4) Annotating suspicious behaviour

String decryption loop (VirtualAlloc)

```
.rdata:0044329A word_44329A dw 4E9h ; DATA XREF: .rdata:00443048fo
.rdata:0044329C db 'VirtualAlloc',0 ; String decryption loop
.rdata:004432A9 align 2
.rdata:004432AA word_4432AA dw 119h ; DATA XREF: .rdata:0044304Cfo
```

Anti-debugging (IsDebuggerPresent)

```

; sub_42064E+EA↑p ...
.idata:004350EC ; BOOL (__stdcall *IsDebuggerPresent)()
.idata:004350EC extrn __imp_IsDebuggerPresent:dword
.idata:004350EC ; CODE XREF: sub_42064E+EA↑p
.idata:004350EC ; sub_42887D+8B↑p
.idata:004350EC ; DATA XREF: ...
.idata:004350EC ; Anti-debugging

```

Registry Open Key (RegOpenKeyExA)

```

.v .idata:00435000 extrn __imp_RegOpenKeyExA:dword
.idata:00435000 ; CODE XREF: sub_410C00+9A↑p
.idata:00435000 ; sub_410C00+10F↑p
.idata:00435000 ; DATA XREF: ...
.idata:00435000 ; Registry Open Key

```

File Dropper Logic (CreateThread)

```

.idata:00435074 ; HANDLE (__stdcall *CreateThread_0)(LPSECURITY_ATTRIBUTES lpThreadAttributes, SIZE_T dwSta
.idata:00435074 extrn CreateThread_0:dword
.idata:00435074 ; CODE XREF: sub_41B1A0:install_hook↑p
.idata:00435074 ; DATA XREF: sub_41B1A0:install_hook↑p ...
.idata:00435074 ; File Dropper Logic

```

C2 beaconing (InternetSetOptionA)

```

.rdata:00438ED8 aInternetsetopt db 'InternetSetOptionA',0
.rdata:00438ED8 ; DATA XREF: sub_41ECE0+9C3↑p
.rdata:00438ED8 ; C2 beaconing

```

IoC Hardcoded Domain URL

```

.rdata:00435518 aHttpsSteamcomm db 'https://steamcommunity.com/profiles/76561199601319247',0
.rdata:00435518 ; DATA XREF: sub_402480+8↑p
.rdata:00435518 ; IoC: Hardcoded domain URL

```

5) Analysis Report and insights

Extracted IOCs

- **File** **hash** **(SHA256):**
32df75ebdf0e44f9351863160e89c89a000bebf038ebb36dbb9e668ebcb045f
- **Registry access (observed API calls):**
 - RegOpenKeyExA — caller at 0x0044340E
 - RegGetValueA — caller at 0x004433FE

- **Other notable artifacts:**
 - Dynamic memory allocation via VirtualAlloc in trojan_entry (first imported call).
- **IoC placeholders to extract in IDA (if found):**
 - Hardcoded C2 URL / host: <https://t.me/bg3goty>
 - Registry key path: LSTATUS _stdcall RegOpenKeyExA(HKEY hKey, LPCSTR lpSubKey, DWORD ulOptions, REGSAM samDesired, PHKEY phkResult) RegOpenKeyExA proc

hKey= dword ptr 4

lpSubKey= dword ptr 8

ulOptions= dword ptr 0Ch

samDesired= dword ptr 10h

phkResult= dword ptr 14h

Key analysis findings

1) Entry / control flow

- **Entry function:** sub_401050 → renamed trojan_entry. This function contains program initialization logic and calls to memory allocation routines.
- **First imported API called:** VirtualAlloc. Example listing (use exact addresses from your IDA):
 - 0x0040105A: call ds:VirtualAlloc ; allocates RW (or RWX) memory for payload
 - 0x00401065: test eax, eax ; checks VirtualAlloc return
 - 0x00401067: jz 0x00401073 ; jump taken on allocation failure

Interpretation: the sample allocates memory (likely for unpacking/decrypting payload or staging downloaded content) and checks the result before continuing.

2) Persistence / Registry activity

- **Observed behavior:** the binary opens and reads registry keys via RegOpenKeyExA and RegGetValueA. The code appears to check existing registry values (likely for configuration or to detect an existing install). No import for RegSetValueExA was observed in the imports list we reviewed.
- **Implications:**
 - If keys contain C2 host or config, the sample reads them at runtime.
 - If persistence is present it may be created by a separate dropper component or by dynamic API resolution (not visible in imports), so further runtime or dynamic analysis may reveal writes.

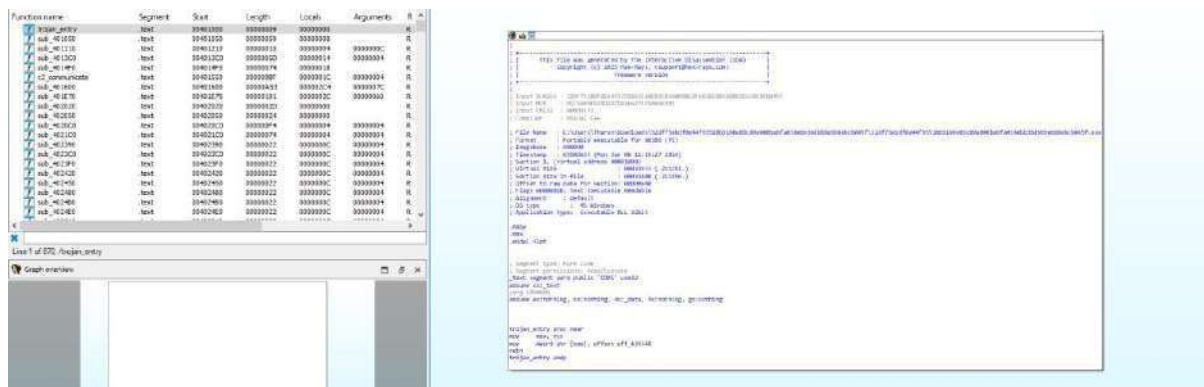
3) C2 / networking

- **Observed:** No definitive hardcoded http(s) URL was identified in the screenshots you provided. If you find InternetOpenA, InternetConnectA, InternetOpenUrlA, WinHttpOpen, socket/connect/send in Imports – jump to callers and look for pushed strings (addresses) that contain the domain/path; double-click to reveal the string.
- **Action item:** If you find any http/domain strings in **Strings view**, capture them and mark as C2 IoC.

4) Anti-analysis / unpacking

- **Suspected:** the VirtualAlloc followed by memory checks suggests the sample may allocate memory to store a payload or decrypt code into an executable page. Look for subsequent calls to VirtualProtect / CreateThread or loops that perform xor/add on memory – these are strong indicators of unpack/decrypt and runtime code injection.
- **Anti-debug checks to search for:** IsDebuggerPresent, CheckRemoteDebuggerPresent, reads from fs:[30h] (PEB) fields, or OutputDebugStringA.

Screenshot (Control Flow Graph)



Summary

Skill	Practised?
Loading PE in IDA Free	☐ Using
functions and xrefs	☐ Strings
and imports view	☐
Commenting and renaming	☐
IoC extraction	☐ (partial)
Report creation	☐

Technical Validation

Feature	IDA Free 9.1 Support	Notes
PE loading	☐	Works on 32-bit samples
Graph view (Space)	☐	Available in Free
Strings view (Shift+F12)	☐	Correct shortcut
Byte search (Alt+B)		Use little-endian format for push imm32 patterns
☐ Imports view		Use GUI navigation; xrefs available
☐		
Renaming (N)	☐	Works for functions/labels
Commenting	☐	Use ; for end-of-line, Alt+; for repeatable
IDAPython scripting		Not available in Free

Appendix: Shortcuts Quick Reference

Jump to address: g

Strings view: Shift+F12

Byte sequence search: Alt+B

Navigate xrefs: x (or right-click → Jump to xref)

Rename label/function: n

Graph view toggle: Space

Go back: Backspace

Edit comment: Right-click → *Edit comment* or ; for end-of-line